



AGENTNOVAS

改进事项与下一阶段路线图

逻辑不足 · 风险优先级 · 0-90 天执行计划 · 上线验收清单

建议：先完成资金与权限安全闭环，再扩大市场与自动交易能力
基于当前本地目录 /Users/zhonghetong/Documents/Codex/2026-08-11/wox 的代码、数据库结构、接口与页面实测结果。

审阅日期	2026 年 8 月 19 日
项目状态	本地 WOX 已构建通过；未推送 Git，未上传服务器
当前域名规划	上传对象暂为 www.tzxsea.com；www.agentnovas.com 尚待 DNS 绑定
保密级别	内部使用 / 运营、技术与管理层参考

AgentNovas · 智能交易中枢

文档导航

本目录为静态导航，便于在 WPS 中快速阅读。

01	管理层结论
02	P0 上线阻断项
03	P1 重要增强项
04	P2 工程与体验优化
05	0-90 天路线图
06	分阶段验收标准
07	上线前检查清单
08	需要业务方最终确认的规则

01 管理层结论

总体判断

网站已经具备完整产品外形和较清晰的组织、策略、运营、运维骨架，但“能演示”与“可承载真实资金/自动交易”之间仍有明显距离。下一阶段应围绕支付、交易、权限、通知、数据授权、监控与发布六条生产链路逐项闭环。

级别	定义	建议处理时间	主要主题
P0	不完成就不应开放真实资金或自动交易	0-30 天	支付对账、实盘路由、独立技术权限、服务端开关、通知、备份发布
P1	影响稳定运营、扩张与合规	31-60 天	亚洲股票数据、多语言、可观测性、API SLA、权限导航、安全强化
P2	影响长期研发效率和体验	61-90 天	代码拆分、测试体系、设计系统、无障碍、lint 技术债

02 P0 上线阻断项

下列事项建议在对外宣传“真实自动交易”或接收真实资金之前全部完成。

编号	问题 / 当前证据	改进动作	完成标准
P0-01	会员支付仍存在演示式地址、倒计时和人工状态	接入唯一订单地址、链上确认、回调查签、到账入账、退款和对账任务	同一订单不重复入账；异常可追溯；每日自动对账
P0-02	真实交易路由默认未开放，平台 AI 周期主要为验证/演示	建立交易执行服务、幂等订单键、状态机、撤单重试、仓位核验和交易所沙箱	沙箱连续 7 天无重复单；断线恢复和紧急停止通过演练
P0-03	运维权限暂挂在 hq_admin	拆分 hq_technical_admin、release_manager、security_admin 和只读 auditor	技术人员无权修改业务资金；业务人员无权读取密钥
P0-04	部分功能开关只隐藏前端入口	为每个高风险/收费/API 模块增加统一服务端 feature guard	关闭后直接访问 API 也返回明确的 403/maintenance 状态
P0-05	Telegram/WhatsApp/邮件目前有队列与偏好，但外部发送闭环未确认	接入供应商、重试、死信、状态回执、模板版本和告警	强制通知在测试环境 99.9%送达并可查回执
P0-06	自动任务密钥本地缺失，发布/回滚/备份仍偏人工	建立 CI/CD、环境密钥托管、迁移前备份、版本回滚和发布审计	一次按钮/流水线完成可回滚发布；恢复演练有记录
P0-07	首页和部分看板把演示 KPI 与真实数据混合	所有数字标明实时/模拟/暂无数据；生产环境禁用假延迟、假在线数和硬编码价格	验收页面不出现无法追溯来源的业务指标
P0-08	平台涉及金融交易与客户敏感数据	完成适用地区的法律、牌照、KYC/AML、隐私、数据跨境和风险披露评审	形成律师/合规签署的上线范围与禁用地区清单

P0 推荐实施顺序

- 1.先冻结真实资金与真实自动下单开关，保留模拟和只读行情。
- 2.完成专用技术角色和密钥隔离，再接入 CI/CD 与备份回滚。
- 3.支付与交易分别建设状态机、幂等、审计和对账，不把逻辑写在页面组件中。
- 4.接通强制通知和系统告警，让资金/交易异常可以被及时发现。

5.最后进行沙箱、故障注入、权限越权、重复回调和断线恢复验收。

03 P1 重要增强项

编号	现状与不足	建议	验收指标
P1-01	韩国、日本、香港、中国股票实时行情未接入	采购合规行情供应商，统一代码映射、交易日历、复权、币种、时区与 K 线聚合	目标市场报价/K 线可用率 ≥99.9%，许可范围有文档
P1-02	公开行情源会受地域和限频影响；Coinbase 本地已超时	服务端缓存、自动熔断、供应商优先级、健康分、速率配额和降级提示	单源故障 30 秒内切换；客户端不出现长时间空白
P1-03	多语言依赖手工字典与 DOM 替换，动态内容可能漏翻	迁移到 message catalog，按页面/组件分包，引入术语库、复数和日期货币本地化	7 种语言无混杂；核心金融术语通过人工复核
P1-04	运营菜单与服务端权限并非处处完全一致	由同一权限定义生成前端导航和 API guard；加入角色快照测试	五级账号逐项验收，无“看得到但点不开”
P1-05	限流目前主要是总开关，IP 名单为精确字符串	接入边缘限流、CIDR、可信代理头、设备指纹、登录风控和逐步阻断	暴力登录与 API 滥用测试可自动阻断并留痕
P1-06	运维状态以基础计数和健康接口为主	增加指标、结构化日志、追踪、任务队列、错误聚合、SLO 和告警	核心接口 p95、错误率、队列延迟和供应商状态可视化
P1-07	AI 已支持自定义端点，但缺少 token 账单与提示词版本	增加模型路由策略、token 用量账本、预算、提示词版本/回滚和输出评估	可按用户/模型/功能查看日周月成本并设置预算
P1-08	客户登录、设备、联系方式属于敏感数据	字段级脱敏、按需解密、查看审计、导出水印、保留期限与删除流程	敏感字段每次查看均有审计记录，越权测试为 0

04 P2 工程与体验优化

主题	问题	建议
页面架构	app/page.tsx 体积大且包含大量内联组件，维护和测试风险高	按路由/领域拆为首页、运营、行情、会员、通知等独立模块，并抽离服务层
旧功能下线	团队任务、月度目标、逾期应收等入口虽隐藏，旧接口/组件仍存在	做调用扫描、数据保留方案和正式 deprecation，确认无依赖后再安全删除
Lint 技术债	全仓库当前 84 个错误、10 个告警；本次目标文件已单独清零	按目录建立基线，先修未定义组件和无障碍，再逐步开启 CI 阻断
测试覆盖	自动测试目前以构建和 2 个页面渲染测试为主	增加单元、API 集成、角色权限、收入分配、浏览器 E2E 与视觉回归
设计系统	部分页面仍是历史样式与新运维样式并存	统一间距、字体、表单、状态、空态、错误和响应式断点
可访问性	旧表单存在 label 关联、图片和键盘操作告警	以 WCAG 2.2 AA 为目标修复语义、焦点、对比度和屏幕阅读器
文档与变更	业务规则散落在聊天、代码与页面文案中	把角色矩阵、分成公式、接口版本、数据字典纳入版本化产品文档

05 0-90 天路线图

阶段	时间	主要交付	建议负责人
阶段 A：安全基线	第 1-2 周	冻结生产交易、拆分技术角色、服务端开关、密钥托管、备份与恢复演练	技术负责人 + 安全
阶段 B：资金闭环	第 3-4 周	支付订单、链上确认、入账、退款、对账、强制通知	后端 + 财务 + 合规
阶段 C：交易闭环	第 5-6 周	沙箱执行、订单状态机、幂等、撤单、持仓核验、紧急停止演练	交易系统 + 风控
阶段 D：数据与运营	第 7-8 周	行情熔断、亚洲股票供应商、SLO、告警、角色导航一致性	数据工程 + 运维
阶段 E：国际化与质量	第 9-10 周	i18n 重构、术语审校、权限/API/收入规则测试、敏感数据审计	前端 + QA + 法务
阶段 F：工程收口	第 11-12 周	拆分单体页面、清理旧功能、降低 lint、视觉回归、上线演练与签署	全栈 + QA + 产品

每周固定治理节奏

- 周一：检查安全、交易、支付和供应商 SLO；确认本周发布范围。
- 周三：执行权限回归、账本对账和异常演练；审查高风险配置变更。
- 周五：发布候选版本、灰度验证、回滚演练；更新风险清单和业务文档。

06 分阶段验收标准

领域	最低验收标准
权限	五级运营账号 + 4 类职能角色逐页逐接口测试；任何越权请求必须 403 并记录审计
支付	订单、地址、确认数、回调、重复回调、超时、退款、对账全部有状态机和幂等测试
交易	沙箱下单/撤单/部分成交/断线/重连/重复请求/紧急停止全部通过，持仓与交易所一致
行情	来源、时间戳、交易对、时区、复权规则明确；多源健康与降级告警可验证
AI	密钥不回显；模型超时与失败可降级；成本可归集；模型输出无法绕过硬风控
通知	强制通知不可关闭；失败重试和死信可查；敏感内容不明文泄露
数据	客户详情、登录记录、组织链和收入分配按最小权限展示；导出和查看有日志
发布	迁移前自动备份；发布可灰度；回滚在规定时间内完成；版本和责任人可审计

07 上线前检查清单

- [] 真实资金开关、自动交易开关默认关闭，并经过双人审批才能开启
- [] 生产、测试、开发数据库和密钥完全隔离
- [] 管理员强制 MFA；技术、财务、审核角色完成最小权限验证
- [] 支付、退款、收入分配、结算和策略作者分成全部完成对账测试
- [] 交易订单幂等、仓位核验、断线恢复和全局紧急停止演练通过

- [] 行情、新闻、股票数据源已确认商业许可、配额和 SLA
- [] 客户隐私、KYC/AML、风险披露、服务条款与禁用地区完成法律审核
- [] 监控、日志、追踪、告警、值班、事故响应和备份恢复流程已演练
- [] 7 种语言核心页面人工审校，无混杂语言和金融术语歧义
- [] 全站无演示价格、假在线数、假延迟或未标注的模拟数据
- [] 关键 API、权限、收入规则、支付与交易 E2E 自动测试进入 CI
- [] 发布版本、数据库迁移、回滚包、负责人和上线窗口已确认

08 需要业务方最终确认的规则

这些项目不是技术实现能自行决定的事项，应在正式上线前形成书面业务决议并版本化。

待确认事项	当前代码口径	需要确认
会员收入	毛收入总部 60% / 分公司 40%；无有效归属总部 100%	是否适用于所有套餐、优惠、退款与税费场景
总部部门分配	网站可分配收益：技术 2.5%、招商 2.5%、运营 15%	是否需要增加财务、客服、风控或预留池
盈利分成	每周正收益收费；20%/19%/18%/16%；亏损不结转	是否需要高水位、亏损追回、结算时区和最低收费门槛
个人代理	月度业绩阶梯 20%–50%，每月清零	业绩定义、退款冲减、跨月订单和离职结算
策略广场	平台 50% / 作者 50%；平台份额再按总部/分公司分配	税费、退款、争议、盗版、作者封禁和下架后的处理
双人审批	策略需 2 名总部审核；运营申请由分公司最终审批且申请人不能自批	是否要求所有资金类申请也必须两名不同审批人
数据保留	审计和历史记录倾向保留	客户关闭账号、隐私删除请求与监管保留期限如何平衡

建议的下一决策会议

先只讨论 P0：生产支付范围、真实交易开放边界、技术/财务角色、双人审批范围、适用国家和数据许可。上述五项确认后，再确定 90 天排期和预算。

文档结束。本路线图与《AgentNovas 网站功能与后台体系说明书》配套使用。